情報処理安全確保支援士試験　科目A-2　中分類25 情報セキュリティ対策　#16

デジタル署名とPKI

だれが作ったかを証明し、その公開鍵が本物であることを保証する

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、RFC 5280・6960・8555・8659、W3C XML Signature、CA/Browser Forum、NIST など）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類25 小分類4・7

1 デジタル署名と MAC
署名・MAC・HMAC・コードサイニング・XML 署名

2 PKI と証明書の運用
CA・RA・VA・CP/CPS・パス検証・CRL・OCSP・CA/B Forum・ACME・CAA・CT

3 応用的な暗号技術
秘密分散・準同型暗号・ゼロ知識証明・TEE・ML-KEM/ML-DSA・暗号アジリティ

過去の午前 II での出方（22回出題）

テーマ	出た回
CRL	H31春・R1秋・R3秋・R6春
RA・VA の役割	R1秋・R4秋・R5秋・R6春・R7秋
XML デジタル署名	R1秋・R5秋・R7秋
OCSP・CPS・CAA	H31春・R3春・R5秋・R6春・R7春
MAC と第三者	R4秋・R6春
デジタル証明書の説明	R5春・R7春

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類25 小分類4・7／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

デジタル署名とメッセージ認証符号

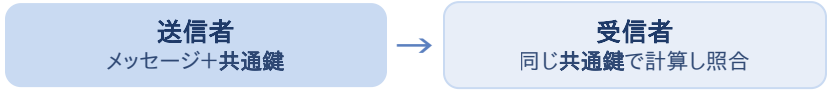
だれの鍵で作り、だれが確かめられるか。

デジタル署名と MAC の違い（R4秋・R6春）

デジタル署名



MAC



	MAC	署名
完全性	受信者が確認	誰でも確認
第三者への証明	できない	できる
否認防止	できない	できる

MAC は受信者も同じ値を作れる → 第三者には「送信者が作った」と証明できない。MAC は公開鍵では作らない。

HMAC：鍵を内外2回使う構造で伸長攻撃を防ぐ（RFC 2104）。

出典：IPA 午前 II 令和4年度秋期 問1・令和6年度春期 問2／NIST FIPS 186-5／RFC 2104

XML 署名とコードサイニング

XML 署名の3つの形（R1秋・R5秋・R7秋）

形	位置関係
エンベロープ署名	署名を**対象の中**に入れる
エンベローピング署名	**署名の中に**対象を包む
デタッチ署名	別々に置く。**同じ XML 文書の別エレメント**にもできる

CMS（S/MIME の構文）や ASN.1（X.509 の記述）は XML 署名では使わない。署名も XML で書く。

コードサイニング

配布者がプログラムに署名
コードサイニング証明書＋タイムスタンプ

利用者が検証
配布者は誰か・改ざんがないか

安全なプログラムであることは**保証しない**。署名鍵を盗まれるとマルウェアにも正規の署名が付く。

出典：W3C「XML Signature Syntax and Processing Version 1.1」／IPA 午前 II 令和7年度秋期 問6

第2章

PKI と証明書の運用

だれが確認し、だれが署名し、だれが答えるか。

PKI の登場人物

申請者
鍵ペアを作り
公開鍵を提出

→

RA 登録局
本人確認・
申請の承認／却下

→

CA 認証局
CA の**秘密鍵**で署名し発行
失効させ CRL を公開

→

VA 検証局
失効状態の問合せに応答
（OCSP レスポンダ）

R5春・R7春 問6 の誤りの選択肢	正しくは
証明書の規格は X.400	**X.509**
申請者の**秘密鍵**に CA が署名	**公開鍵を含む情報に**
ルート CA の**公開鍵**で署名	**秘密鍵で**

CPS（R5秋・R7春 問9）：認証局の認証業務の運用の詳細を規定した文書。CP は発行の方針。

日本政府の PKI は **GPKI**（政府認証基盤）。

出典：RFC 5280・RFC 3647／IPA 午前 II 令和5年度秋期 問3・令和7年度秋期 問4・令和7年度春期 問6・問9

証明書パス検証と失効の確認

ルート CA 証明書（自己署名）
OS・ブラウザに組み込み＝信頼の起点

中間 CA 証明書
ルートの秘密鍵で署名

サーバ証明書 www.example.jp
中間 CA の秘密鍵で署名

下から順に、署名・期限・**失効**・用途を確かめる（RFC 5280 6章）。

方法	しくみ
CRL	**有効期限内に失効した**証明書の**シリアル番号**の一覧
OCSP	証明書ごとにレスポンダへ問い合わせ
OCSP ステープリング	サーバが応答を TLS で同送

CRL の誤りの選択肢：期限切れのもの・公開鍵を載せる、「失効後1年間」の義務、ルート証明書があれば CRL 不要。

出典：RFC 5280・RFC 6960／IPA 午前 II 平成31年度春期 問1・問2、令和6年度春期 問6

証明書の発行を管理する：CA/B・ACME・CAA・CT

仕組み	何をするか	いつ効く
CA/Browser Forum	発行基準（Baseline Requirements）。最大有効期間 398 日 → 2029年に 47 日へ短縮が決定	業界のルール
ACME	HTTP-01・DNS-01 のチャレンジでドメイン管理を確かめ、発行・更新を自動化（Let's Encrypt）	発行・更新のとき
CAA レコード	発行してよい CA を DNS で指定。CA は発行前に確認	発行の**前**に防ぐ
CT	発行した証明書を公開ログに登録。所有者が監視	発行の**後**に見つける

```
example.jp.  CAA 0 issue "letsencrypt.org"
example.jp.  CAA 0 iodef "mailto:security@example.jp"
```

R3春・R6春：CAA の効果は「**不正なサーバ証明書の発行を防ぐ**」。鍵マーク＝安全、URL 短縮、スパム判定は誤り。

出典：CA/Browser Forum Baseline Requirements（Ballot SC-081）／RFC 8555・RFC 8659・RFC 6962／IPA 午前 II 令和6年度春期 問15

第3章

応用的な暗号技術

見せずに計算し、見せずに証明し、分けて守る。

秘密分散・準同型暗号・ゼロ知識証明・TEE

秘密分散 (3, 5)



3つ集まれば復元、2つ以下では何も分からない。

準同型暗号

```
E(3) ⊕ E(5) = E(8)   → 復号すると 8
```

中身を見せずにクラウドで集計。完全準同型（FHE）は重い。

技術	できること
ゼロ知識証明	生年月日を見せずに「20 歳以上」だけを証明
TEE	CPU 内の隔離領域で処理。OS が乗っ取られても守る（SGX・TrustZone）
TPM	鍵の保管と起動の計測をするチップ（TEE とは別）

選択肢では「暗号文のまま計算」＝準同型、「分けて k 個で復元」＝秘密分散、「明かさず証明」＝ゼロ知識証明。

出典：IPA「支援士試験 シラバス（案）」用語例〔応用的な暗号技術〕／Shamir「How to Share a Secret」1979年

PQC への移行と暗号アジリティ

今	置き換え先（NIST 2024）
RSA・ECDH の鍵共有	ML-KEM（FIPS 203）
RSA・ECDSA の署名	ML-DSA（FIPS 204）
（予備の署名）	SLH-DSA（FIPS 205）

移行期は ECDH＋ML-KEM の**ハイブリッド鍵交換**が TLS で使われ始めた。

暗号アジリティを高める

暗号の一覧（インベントリ）を作る
どこで何を使っているか

アルゴリズムを設定で選べる設計
直接書き込まない

証明書・鍵の自動更新
ACME など

独自の非公開の暗号は評価されておらず危険。

出典：NIST FIPS 203・204・205（2024）・CSWP 39 Considerations for Achieving Cryptographic Agility

まとめ：本番での問われ方

MAC：共通鍵で作る → 受信者が完全性を確認。第三者には証明できない。**署名：**送信者の秘密鍵で作り、公開鍵で誰でも検証。

XML 署名：デタッチ署名は同じ文書の別エレメントにも。CMS・ASN.1 は使わない。

役割：RA＝本人確認と承認、CA＝署名と発行、VA＝失効の問合せに応答、CPS＝運用の詳細の文書。

CRL：期限内に失効した証明書のシリアル番号。**OCSP：**失効情報の問合せ。

証明書：規格は X.509。CA は公開鍵を含む情報に、CA の秘密鍵で署名。**CAA：**不正な発行を防ぐ。

応用：秘密分散・準同型・ゼロ知識証明・TEE・ML-KEM/ML-DSA・暗号アジリティ。

出典：IPA 午前 II（このPDFの問題演習）／IPA「支援士試験 シラバス（案）Ver.0.1」